Ejercicio de derechos del titular

Actividad 6 NortiShop

Asignatura: Seguridad y Protección de Datos

Caso: Plataforma de comercio electrónico NortiShop

Integrantes: Ariel Van Kilsdonk y Carlos Orellana

Fecha: 11 de noviembre de 2026

1 Introducción

Implementamos el ejercicio de derechos sobre el sistema NortiShop del proyecto. La cuenta del cliente es el canal de solicitudes; cada caso tiene un identificador, un plazo y un historial de estados. Ningún dato se entrega ni modifica antes de verificar la identidad. La solución usa el inventario del Hito 1 y el consentimiento separado del Hito 3. Las pruebas son con clientes sintéticos.

La Ley 19.628 rige a la fecha de esta entrega. El procedimiento de 30 días, la portabilidad y la oposición descritos en la Ley 21.719 se prepararon para su entrada en vigencia el 1 de diciembre de 2026. Los plazos de conservación de pedidos y facturas siguen siendo propuestas del caso y requieren revisión jurídica antes de operar con datos reales.

2 Canal y registro de solicitudes

El titular inicia sesión y usa el Centro de privacidad en /privacidad. El formulario envía POST /api/derechos/solicitudes y el seguimiento se consulta en GET /api/derechos/solicitudes. La API siempre filtra por customer_id de la sesión. Para una solicitud ajena o inexistente devuelve el mismo 404. El equipo DPO puede revisar estados y una prórroga fundamentada, sin recibir el contenido de los datos personales.

Tabla	Campos y uso
rights_requests	public_id, customer_id, subject_ref, type, status, received_at, due_at, verified_at, evaluated_at, executed_at, closed_at, resolution, payload_enc y datos de verificación.
rights_request_events	request_id, status, at, actor_ref y note. Conserva cada transición sin copiar los valores personales modificados.
erasure_tombstones	customer_public_id y erased_at. Permite reaplicar una supresión si se restaura un respaldo antiguo.

Los estados son recibida, verificacion, evaluacion, ejecutada o rechazada y cerrada. Los valores propuestos para rectificación se cifran y se borran al cerrar. La respuesta indica el resultado y la causa si se rechaza. El plazo configurado es de 30 días corridos desde la recepción, con una sola prórroga de hasta 30 días.

3 Verificación de identidad

Toda solicitud requiere sesión del cliente y reingreso de contraseña. Acceso, portabilidad, supresión y cambio de correo exigen además un código de un solo uso enviado al correo registrado. El código vence a los 10 minutos, se guarda solo su hash y admite hasta cinco intentos. El servicio no pide cédula ni selfie. La solicitud queda en verificacion si la comprobación falla; no ejecuta cambios ni habilita la descarga.

4 Mecanismos implementados

4.1 Acceso y portabilidad

Tras verificar la identidad se habilita durante 24 horas un archivo JSON UTF-8. Incluye perfil, direcciones, pedidos e ítems, pagos sin credenciales de pasarela, despachos, facturación, NortiPuntos, reseñas, tickets, analítica, consentimiento, solicitudes y actividad de seguridad del titular. Todas las consultas se acotan por su customer_id o seudónimo de finalidad. Se excluyen hashes de contraseña, tokens, códigos de autorización, detalles internos de alertas y datos de otros clientes. La descarga queda auditada.

4.2 Rectificación

Aceptamos nombre, correo, teléfono o una dirección identificada por su ID. La validación rechaza campos desconocidos y exige que la dirección pertenezca al titular. El cambio actualiza la cuenta y, cuando corresponde, los pedidos aún en curso. Las facturas emitidas se mantienen como documento histórico. El evento de auditoría consigna campos y número de pedidos actualizados, sin guardar el valor anterior ni el nuevo.

4.3 Supresión

Si hay pedidos en curso, la solicitud se rechaza con una razón concreta y puede presentarse de nuevo al terminar la operación. Si procede, se borran direcciones, medios de pago guardados, sesiones, credenciales, puntos y analítica; se vacían tickets y se desvinculan reseñas. Los pedidos entregados conservan datos comerciales mínimos, sin nombre, teléfono ni calle. Los perfiles de facturación quedan marcados como bloqueados para su conservación legal. La cuenta se marca como suprimida, se revocan consentimientos y se genera una orden de baja para el proveedor de mailing. El despachador confirma su entrega y reintenta si falla. Una lápida evita que un respaldo reintroduzca la cuenta.

4.4 Oposición

La solicitud de oposición se aplica al correo de marketing. Después de verificar la contraseña, se revoca el consentimiento vigente, el cliente sale de la audiencia y se registra la orden suppress para el proveedor. El despachador entrega la baja con una referencia seudónima y marca la orden como enviada solo tras su aceptación. Si el consentimiento ya estaba retirado, la orden igualmente se registra. El historial deja constancia de la solicitud y su cierre. Este tratamiento es independiente de los mensajes transaccionales de una compra.

5 Pruebas con solicitudes concretas

Solicitud sintética	Comprobación y resultado
Acceso y portabilidad de Ana	Antes del código, descarga denegada. Después, JSON con factura, ticket, analítica y despacho de Ana; sin datos de Bea.
Rectificación de teléfono	El teléfono cambia a +56987654321. La auditoría registra el campo telefono, sin el número.
Supresión de Ana	Correo y credenciales desaparecen; el perfil de factura queda bloqueado; se crea orden suppress y lápida.
Oposición de Ana	Marketing deja de estar otorgado; el despachador entrega suppress y la audiencia del proveedor queda vacía.
Solicitante no verificado	Contraseña errónea: solicitud continúa en verificacion y la exportación no se entrega.

Estas pruebas se ejecutan con scripts/probar_actividades_6_7.py. Las seis pruebas directas y las 51 pruebas HTTP del sistema terminaron correctamente el 11 de noviembre de 2026. La salida de la batería HTTP está en evidencias/resultado_suite_http_actividades_6_7.txt.

6 Conclusión

El flujo separa recepción, verificación, evaluación y ejecución. La identidad se comprueba antes de cualquier acción sobre datos; la exportación está acotada al titular; y rectificación, supresión y oposición dejan evidencia sin copiar datos personales al registro de auditoría. Para una puesta en producción faltan la integración real del proveedor de correo y mailing, la revisión de plazos legales y controles de base de datos con usuarios y permisos propios.

7 Referencias

Biblioteca del Congreso Nacional de Chile. Ley 19.628, texto vigente al 11-11-2026. https://www.bcn.cl/leychile/navegar?idNorma=141599

Biblioteca del Congreso Nacional de Chile. Ley 21.719, arts. 4 a 11, vigencia desde 01-12-2026. https://www.bcn.cl/leychile/navegar?idNorma=1209272

Repositorio NortiShop. Actividad 3, Informe Hito 1; Sistema_NortiShop/nortishop/rights.py, consent.py y schema.sql; scripts/probar_actividades_6_7.py.